Securing VMWare ESXi Part 2: Access Controls

trimarcsecurity.com/hub-post/securing-vmware-esxi-part-2

Demetrios Mustakas January 7, 2022

Updated: Jul 17, 2024

Introduction

This is the second part of a multi-article series exploring ESXi hypervisor architecture and its many security features. In this article we are going to focus on physical and network access controls.

Access Controls

Hypervisor security takes into consideration Physical, Account, and Network access controls. Everything from direct KVM (Keyboard, Video, Mouse) interfaces with the ESXi host server to remote networked access and management must be planned and security must be considered.

Physical Access

One obvious and often overlooked access control for ESXi hosts is direct physical access by unauthorized personnel.

It is very important that an organization create and enforce policies and practices with regards to physical access to the ESXi hosts. Hosts should be installed in secure locations such as environmentally appropriate utility rooms and datacenters. Sign in logs (physical or electronic) and other methods should be implemented in order to track any access to those locations, even by authorized personnel. Consider locking racks for added security to the ESXi hosts and virtual infrastructure stack. If there is other equipment in the room that may require maintenance locking the individual server racks will add security. Eliminate “backdoor” ways to access rooms where the virtual infrastructure stack resides. Ensure there are no shared closet spaces or movable partitions and that the room is operationally secured by the locks at the main door.

Account access

The ESXi ‘Root’ account should only be used when no other method of access is available. It is the emergency “break glass” account and should not be used regularly for operational administrative tasks. In nearly every case, the privileges that are assigned to users to perform tasks on ESXi hosts should be managed by vCenter.

The root administrator account should have a password greater than 20 characters long and changed at least once a year (or when an administrator leaves the organization). Access to this account should be monitored and logged whenever an administrator requires the user of the account, and the password should be changed before it is safeguarded once again.

Consider creating at least one named user account or group and assign full administrative privileges on each host to perform administrative tasks. For better auditing, ensure that any account with the Administrator role on an ESXi host is assigned to a specific user with a named account.

The Direct Console User Interface (DCUI) is a menu-based interface that is accessed from the host console and allows for manual configuration changes to be made directly to an ESXi host. Consider disabling the DCUI service locally on each ESXi host. If this is not possible, Trimarc recommends restricted physical access controls to protect against configuration changes being possible using the DCUI. Access and use of the DCUI should be limited to troubleshooting and recovery efforts.

Network Access

The local ESXi Shell and remote Secure Shell (SSH) can be enabled from the DCUI circumventing configurations from a vCenter management server. The ESXi Shell includes a set of fully supported ESXCLI commands and a set of commands for troubleshooting and remediation. SSH allows remote access across a network connection. Unfortunately, attackers often look to exploit access to ESXi hosts in the same manner as administrators.

To reduce the risk of unauthorized access, enable the ESXi Shell for troubleshooting only and disable after troubleshooting ends. Enable access to the ESXi Shell or SSH only if strict network access security policies are enforced. Provide only trusted users with ESXi Shell login access. Use the vSphere client, or one of the VMware CLIs or APIs to administer the ESXi hosts. If you use the ESXi Shell or SSH, limit the accounts that have access and set timeouts to reset SSH to disabled.

The VMware Host Client is used to manage a single ESXi host. This is distinct from the vSphere Web Client used to connect to vCenter Server and manage multiple ESXi hosts. It can be used to conduct emergency management when vCenter Server is unavailable. The VMware Host Client is different from the vSphere Web Client, regardless of their similar user interfaces. This necessitates special consideration as direct host access can circumvent security controls normally centralized using vCenter.

vSphere Web Client is used to administer ESXi hosts that are managed by a vCenter Server. Any ESXi host that is managed by a vCenter server should not be managed directly with the VMware Host Client (similar to the recommendation to not use DCUI). If hosts are managed using a scripting interface or API, it is recommended that hosts are not

targeted directly. Instead, target the vCenter Server system that manages the host and specify the host name. Directly managing hosts should be restricted where possible.

Conclusion

Securing the ESXi host is crucial to vSphere security. It is important to plan the configuration of host Access Controls. Consider centralizing all privileges for host permissions using vCenter wherever possible and only directly access hosts in recovery or emergency situations.

References and Additional Information

- Securing VMWare ESXi Series
- Accessing Direct Console User Interface (DCUI) from an SSH session (vmware.com)
- How to access DCUI/Console of ESXi using ALT+F Keys (2148363) (vmware.com)
- Assigning Privileges for ESXi Hosts
- Completely locked out of ESXI host. No DCUI, No SSH, No Web UI : vmware (reddit.com)

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.

Trimarc performs security assessments that cover Active Directory, Azure AD & Microsoft Office 365, and VMWare. If you would like to improve the security of your VMWare infrastructure, let us know and we can discuss the Trimarc Virtual Infrastructure Security Assessment (VISA).

How to contact Trimarc

Version	Release Name	Release Date	Build Number
ESXi 7.0 Update 2a	ESXi 7.0 Update 2a	2021/04/29	17867351
ESXi 7.0 Update 2	ESXi 7.0 Update 2	2021/03/09	17630552
ESXi 7.0 Update 1d	ESXi 7.0 Update 1d	2021/02/02	17551050
ESXi 7.0 Update 1c	ESXi 7.0 Update 1c	2020/12/17	17325551
ESXi 7.0 Update 1c (security Only)	ESXi 7.0 Update 1c (security Only)	2020/12/17	17325020
ESXi 7.0 Update 1b	ESXi 7.0 Update 1b	2020/11/19	17168206
ESXi 7.0 Update 1a	ESXi 7.0 Update 1a	2020/11/04	17119627
ESXi 7.0 Update 1	ESXi 7.0 Update 1	2020/10/06	16850804
ESXi 7.0b	ESXi 7.0b	2020/06/23	16324942
ESXi 7.0 GA	ESXi 7.0 GA	2020/04/02	15843807